Análisis estático y recuperación autorizada: caracterizar sin ejecutar

Del caso completo a la pieza sospechosa

En la lección anterior se trabajó el caso completo: transformar una solicitud en preguntas, preservar evidencia, construir una cronología y redactar un hallazgo reproducible. Dentro de un caso así aparece, muchas veces, un archivo del que se sospecha: un adjunto, un ejecutable encontrado en un equipo, un contenedor protegido. Antes de decidir qué hacer con él hay que **caracterizarlo**.

La pregunta de esta lección es:

> ¿Qué puede afirmarse de un archivo examinándolo sin ejecutarlo, y dónde termina esa certeza?

Cuatro ideas ordenan la lección:

1. **mirar no es ejecutar**: el análisis estático describe el archivo a partir de sus bytes, sin correrlo; por eso es seguro, pero también limitado;
2. **capacidad no es comportamiento**: que un archivo *pueda* hacer algo no demuestra que *lo haga*;
3. **un indicador no es un veredicto**: las cadenas, las APIs y la extensión se clasifican y se contrastan, no se leen como sentencia;
4. **el alcance es el límite**: la recuperación autorizada usa una lista acotada de candidatos; salir de ella deja de ser forense y pasa a ser intrusión.

El recorrido de la lección es corto y deja productos encadenados:



1. Análisis estático y análisis dinámico

Existen dos formas complementarias de estudiar un artefacto sospechoso:

	Análisis estático	Análisis dinámico
Qué hace	Examina el archivo **sin ejecutarlo**	**Ejecuta** el archivo en un entorno controlado y observa qué ocurre
Qué responde	¿Qué es, qué contiene, qué podría hacer?	¿Qué hace realmente al correr?
Riesgo	Bajo: el archivo no actúa	Alto: el archivo actúa; exige aislamiento estricto
Límite	No ve comportamiento; la ofuscación puede ocultar cadenas	Solo ve lo que ocurre en esa ejecución y entorno

Esta lección se concentra en el **análisis estático** y en diseñar —sin ejecutar— la prueba dinámica que vendría después (lección 14). El orden natural es estático primero: es más seguro y orienta qué buscar al ejecutar.

Por qué no se ejecuta en esta clase

Ejecutar una muestra desconocida puede cifrar archivos, abrir conexiones, instalar persistencia o propagarse. El análisis dinámico solo se hace en un entorno preparado para ello: máquina virtual desechable, *snapshot* previo, red simulada o aislada y plan de reversión. En esta lección el entorno no está preparado para ejecución, así que la muestra se trata como **inerte** y nunca se corre.

2. Manejo seguro de la muestra

NIST SP 800-83 (manejo de incidentes de malware) insiste en que la primera decisión es de **contención**, no de análisis. Antes de examinar:

- **aislar**: estación sin red o con red controlada, sin montar unidades del sistema anfitrión con escritura;
- **no ejecutar**: nada de doble clic, "abrir con", ni renombrar para que el sistema lo asocie a un programa;
- **no publicar**: subir la muestra a un servicio en línea (por ejemplo, un analizador público) la **distribuye**; puede quedar indexada y, si es un caso real, filtra información;
- **trabajar sobre copia**: se verifica el hash, se copia y se analiza la copia con permiso de solo lectura.

La integridad primero

Como en toda la asignatura, el análisis no empieza hasta que el hash coincide con el manifiesto. Una discrepancia detiene el trabajo: si el archivo no es el que se preservó, cualquier conclusión queda invalidada.

3. Identificar el tipo real

La extensión de un archivo (`.pdf` , `.docx` , `.jpg`) es solo una etiqueta del nombre; cualquiera puede cambiarla. El tipo **real** se determina por los primeros bytes del archivo, llamados *magic bytes* o firma.

Firma (hex)	Texto	Tipo real
`4D 5A`	`MZ`	Ejecutable de Windows (PE / DOS)
`25 50 44 46`	`%PDF`	Documento PDF
`50 4B 03 04`	`PK..`	Contenedor ZIP (incluye `.docx` , `.xlsx` , `.jar`)
`7F 45 4C 46`	`.ELF`	Ejecutable de Linux
`FF D8 FF`	—	Imagen JPEG

La herramienta `file` lee esa firma y nombra el tipo probable. Una **discrepancia** entre la extensión y el tipo real —por ejemplo, un archivo llamado `actualizacion.pdf` que en realidad es un ejecutable— es un hecho observable que merece registrarse. No es, por sí sola, prueba de intención: también hay archivos legítimos mal nombrados. Pero un ejecutable disfrazado de documento es un indicador que sube la prioridad del análisis.

4. Hashes: identidad e integridad

El hash criptográfico (SHA-256 en este curso) cumple dos funciones en el análisis estático:

1. **integridad**: comprobar que la muestra no cambió desde que se preservó;
2. **identidad**: un hash identifica una muestra exacta; dos archivos con el mismo SHA-256 son, a efectos prácticos, el mismo contenido.

El hash **no** dice si un archivo es malicioso. Un archivo benigno y uno malicioso tienen, cada uno, su hash; el valor en sí no clasifica. En investigaciones reales, los hashes se comparan contra listas conocidas (buenas o malas), pero esa comparación es una fuente externa más, con su propia confiabilidad, no una verdad absoluta.

5. Metadatos

Los metadatos describen el archivo sin ser su contenido principal: tamaño, fechas, autor declarado, aplicación que lo creó, fecha de compilación. Se obtienen sin ejecutar el archivo.

Metadato	Qué aporta	Precaución
Tamaño	Compara con lo esperado; un instalador de 2 KB es sospechoso	Por sí solo no concluye nada
Fechas del sistema de archivos	Orientan la cronología	Se alteran con facilidad; no son confiables como prueba única
Autor o empresa declarados	Pista de origen	Son campos editables: pueden falsificarse
Fecha de compilación (en PE)	Orienta cuándo se construyó	También puede manipularse

La **ausencia** de metadatos también es un dato, pero solo si se examinaron con una herramienta capaz de leerlos: un archivo que dice ser de un gran proveedor y no está firmado digitalmente levanta una pregunta. Si la herramienta usada no lee ese campo, corresponde registrar «no examinado», no «ausente». `stat`, por ejemplo, solo informa propiedades del sistema de archivos.

6. Cadenas e indicadores de compromiso

Un archivo contiene texto legible incrustado: rutas, dominios, mensajes, nombres de funciones. La herramienta `strings` los extrae. Cada cadena es una **pista**, no una conclusión, y se clasifica por su fuerza:

Clase	Definición	Ejemplos
Fuerte	Específico de un comportamiento concreto	Ubicación real de arranque automático (`HKCU\Software\Microsoft\Windows\CurrentVersion\Run`); dominio de mando y control; nombre de *mutex* poco común
Contextual	Describe una capacidad posible, no un hecho	Nombres de funciones como `WinHttpOpen` (red), `RegSetValueExW` (registro), `CreateFileW` (archivos)

Cuidado con las imitaciones: una clave propia como `HKCU\Software\MiEmpresa\Run` **no** es una ubicación de autoarranque, aunque termine en `Run`. Windows solo ejecuta automáticamente lo registrado en ubicaciones específicas. | **Débil o señuelo** | Común en software legítimo o puesto para confundir | `kernel32.dll`, `Microsoft Corporation`, `Update complete` |

Indicadores de compromiso (IoC)

Un **IoC** es un dato observable que sugiere actividad maliciosa: un dominio, una IP, un hash, una clave de registro, un nombre de archivo. Los IoC del análisis estático son **potenciales**: el archivo los contiene, pero el análisis no demuestra que se hayan usado. Se documentan con su contexto y su clasificación, nunca como lista de culpas.

Falsos positivos

Una cadena puede engañar:

- un dominio incrustado puede ser un señuelo que nunca se contacta;
- un nombre de API indica que el archivo **puede** llamar esa función, no que la ejecute;
- cadenas de marcas conocidas pueden estar puestas para parecer legítimo.

Por eso cada indicador se acompaña de un posible falso positivo. Esa honestidad es lo que separa un análisis de una acusación.

> **Dominios en los casos del curso.** Los casos usan el sufijo reservado `.invalid`, que por norma nunca resuelve, para no apuntar a dominios reales. Es una convención del laboratorio: analícenlo **como si fuera un dominio real**. Que no resuelva no prueba que sea un señuelo, y en un caso real un dominio que hoy no resuelve puede haber funcionado ayer.

7. Estructura de un ejecutable

Los ejecutables tienen una estructura interna que se puede leer sin correrlos. En el formato PE de Windows, las partes relevantes para el análisis estático son:

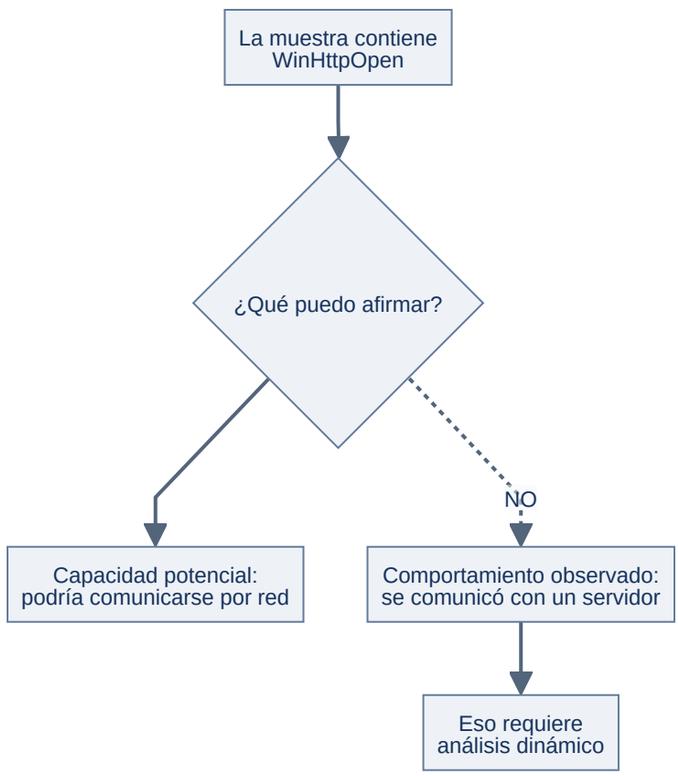
Parte	Qué es	Qué aporta
Encabezado (`MZ` , `PE`)	Firma y cabeceras	Confirma el tipo y la arquitectura
Secciones (`.text` , `.data` , `.rsrc`)	Bloques de código, datos y recursos	Describen cómo está organizado el archivo
Tabla de *imports*	Funciones de bibliotecas externas que el archivo declara usar	Sugiere capacidades (red, registro, archivos, procesos)
Tabla de *exports*	Funciones que el archivo ofrece a otros	Relevante en bibliotecas (DLL)
Recursos	Iconos, textos, otros archivos incrustados	A veces esconden *payloads* o configuraciones

Los *imports* son especialmente útiles: un archivo que declara `WinHttpOpen` , `CreateProcessW` y `RegSetValueExW` **tiene la capacidad** de hacer red, lanzar procesos y escribir el registro. Capacidad, otra vez, no es comportamiento: hay programas legítimos que usan exactamente esas funciones.

Herramientas como `Ghidra` interpretan la estructura PE para examinar secciones, la tabla de *imports* y el código ensamblador sin ejecutar la muestra. En esta lección solo se usan `file` , `strings` y una vista en crudo: permiten reconocer la firma y los nombres de sección, y encontrar **nombres de funciones como texto**. Encontrar `WinHttpOpen` con `strings` no demuestra que exista una entrada en la tabla de importación ni código que llame a esa función. La redacción correcta es: «contiene nombres de funciones asociados a red; su importación y su uso no se verificaron».

8. Capacidad potencial frente a comportamiento observado

Es la distinción central de la lección.



Una ficha de análisis estático honesta usa un lenguaje acotado:

Sobreafirmación	Redacción acotada
"El archivo roba datos."	"La muestra contiene nombres de funciones de red y una ruta de caché; su uso efectivo no se verificó."
"Se conecta al servidor del atacante."	"La muestra referencia un dominio `.invalid` ; el contacto no se verificó."
"Instala persistencia."	"La muestra contiene una referencia a una clave de arranque automático, compatible con persistencia."

9. Mapeo a MITRE ATT&CK

MITRE ATT&CK es un catálogo de tácticas y técnicas que usan los adversarios. Sirve para describir, con un vocabulario común, qué *podría* hacer una muestra. En el análisis estático el mapeo es **tentativo**: se basa en

capacidades, no en comportamiento.

Indicador estático	Táctica / técnica compatible	Redacción
Clave `...\CurrentVersion\Run`	Persistencia (T1547.001)	"Contiene el texto de una ubicación de autoarranque, compatible con persistencia."
Nombres de funciones de red + dominio externo	Comando y control (TA0011), por ejemplo T1071.001	"Contiene indicios de comunicación por red; el contacto efectivo requiere confirmación dinámica."
Extensión que no coincide con el tipo real	Evasión: Masquerade File Type (T1036.008)	"El nombre presenta como documento un archivo cuya firma es de ejecutable, compatible con enmascaramiento."
Referencia a copia/borrado de archivos	Impacto o evasión	"Podría manipular archivos; no observado."

El mapeo **no** afirma que la técnica se ejecutó. Es una hipótesis estructurada que guía el análisis dinámico posterior.

10. Recuperación autorizada frente a fuerza bruta abierta

Un contenedor protegido (un ZIP cifrado, un documento con contraseña) puede ser parte del caso. Recuperar su contenido es legítimo **solo** dentro de un alcance definido.

	Recuperación autorizada	Fuerza bruta abierta
Alcance	Lista acotada de candidatos entregada para el caso	Diccionarios amplios o espacio completo de contraseñas
Autorización	Explícita, para ese contenedor	Ausente o difusa
Registro	Herramienta, versión, parámetros, lista, tiempos	—
Resultado si falla	Agotar la lista es un resultado válido; se escala	Se "sigue intentando" hasta entrar

La diferencia no es técnica sino de **alcance y autorización**. Probar cinco contraseñas que alguien autorizó para un contenedor específico es recuperación; probar millones contra cualquier archivo que aparezca es un ataque. El mismo comando puede ser una cosa o la otra según el alcance que lo respalde.

Qué demuestra y qué no la recuperación

- **demuestra**: que se obtuvo acceso al contenido del contenedor;
- **no demuestra**: quién lo creó, con qué intención, ni que el contenido sea lícito.

El contenido recuperado se verifica por hash contra el valor esperado: eso prueba que es exactamente el documento previsto, no quién lo puso allí.

Condiciones de detención

Se detiene y se escala cuando:

- el hash del contenedor o de la muestra no coincide;
- el contenido recuperado difiere del esperado;
- la lista autorizada se agota sin resultado.

Agotar la lista **no** autoriza a ampliarla. Un "no se pudo recuperar con lo autorizado" es una respuesta forense completa.

11. Ejemplo resuelto - muestra CERRO VERDE (ficticia)

Llega un adjunto `informe-pagos.docx` dentro de un caso. Se verifica su hash contra el manifiesto: coincide. Se copia y se analiza la copia.

Tipo y metadatos

```
file informe-pagos.docx  ->  PE32 executable (GUI) Intel 80386
head -c 2 ... | od -An -tx1  ->  4d 5a
```

La extensión dice documento; la firma dice ejecutable. **Hallazgo observable:** discrepancia de tipo. Sube la prioridad.

Cadenas

```
strings -n 6 ...
HKCU\Software\Microsoft\Windows\CurrentVersion\Run   (fuerte: autoarranque)
pagos-sync.cerro-verde.invalid    (fuerte: dominio externo)
WinHttpOpen                       (contextual: nombre de función de red)
RegSetValueExW                    (contextual: escribe registro)
Microsoft Corporation             (débil: común/señuelo)
```

Interpretación acotada

Campo	Contenido
Resultado observado	La muestra es un PE32 con extensión `.docx`; contiene como texto una ubicación de autoarranque, un dominio externo y nombres de funciones de red y registro.
Interpretación	Hay indicios compatibles con persistencia y comunicación; no se verificó que implemente esas capacidades ni que se ejecuten.
Confianza	Media: varios indicadores fuertes coinciden, pero nada se ejecutó.
Alternativa	Un instalador legítimo mal nombrado también usa esas APIs; el dominio podría ser señuelo.
Limitación	El análisis estático no demuestra que la persistencia o la conexión ocurrieran.
Recomendación	Ejecutar la prueba dinámica diseñada (VM desechable, red simulada, monitoreo, reversión).

Conclusión de la etapa

> La muestra `informe-pagos.docx` es en realidad un ejecutable de Windows con indicadores de persistencia y comunicación de red. El análisis estático aporta indicios de capacidad, no comportamiento. Se recomienda análisis dinámico en entorno aislado antes de afirmar actividad maliciosa.

12. Errores frecuentes

- Ejecutar la muestra "para ver qué hace" en una estación sin preparación.
- Subir la muestra a un servicio público y filtrar información del caso.
- Leer una cadena o la extensión como veredicto de malware.
- Afirmar comportamiento ("se conectó", "robó") a partir de capacidad.
- Confundir ausencia de detección con ausencia de amenaza, o viceversa.
- Ampliar la lista de candidatos cuando la autorizada no abre el contenedor.
- Guardar una ficha sin las salidas y los hashes que la respaldan.
- No declarar falsos positivos ni explicaciones alternativas.

13. Preparación para la actividad

Antes de la clase (unos 20 minutos), lean las secciones 1, 3, 6, 8 y 10. El resto es consulta durante la actividad. Lleguen con claro:

1. cómo `file` determina el tipo por *magic bytes* y por qué la extensión no basta;
2. la diferencia entre capacidad potencial y comportamiento observado;
3. la distinción entre recuperación autorizada y fuerza bruta abierta, y sus condiciones de detención;
4. un lenguaje acotado: "contiene", "referencia", "es compatible con", en vez de "hace" o "roba".

Durante la actividad, la autorización del caso es el límite: la muestra no se ejecuta y el contenedor se recupera solo con la lista entregada.

14. Glosario

Término	Definición
Análisis estático	Examen de un archivo sin ejecutarlo
Análisis dinámico	Ejecución controlada del archivo para observar su comportamiento

Término	Definición
Magic bytes	Primeros bytes que identifican el tipo real de un archivo
Hash	Valor que identifica el contenido y permite verificar integridad
Metadato	Dato descriptivo del archivo que no es su contenido principal
Cadena	Secuencia de texto legible incrustada en un archivo
IoC	Indicador de compromiso: dato observable asociado a actividad maliciosa
Capacidad potencial	Lo que un archivo podría hacer según su estructura
Comportamiento observado	Lo que un archivo hace efectivamente al ejecutarse
PE	Formato de ejecutable de Windows (Portable Executable)
Sección	Bloque interno de un ejecutable (código, datos, recursos)
Import	Función externa que un ejecutable declara usar
ATT&CK	Catálogo MITRE de tácticas y técnicas de adversarios
Recuperación autorizada	Obtención de contenido protegido dentro de un alcance definido
Fuerza bruta abierta	Prueba masiva de contraseñas sin alcance acotado
Falso positivo	Indicador que parece malicioso pero tiene explicación benigna

Fuentes

- NIST SP 800-83 Rev. 1 - Guide to Malware Incident Prevention and Handling. Manejo seguro, contención y análisis de malware.
- NIST SP 800-86 - Guide to Integrating Forensic Techniques into Incident Response. Examen y análisis dentro del proceso forense.
- MITRE ATT&CK Enterprise. Tácticas y técnicas para describir capacidades.
- MITRE ATT&CK - Persistence: Registry Run Keys (T1547.001). Ejemplo de técnica compatible con un indicador estático.
- Ghidra. Herramienta de análisis estático de ejecutables.
- ISO/IEC 27042:2015 - Analysis and interpretation of digital evidence. Repetibilidad, reproducibilidad e interpretación.